

STUDY GUIDE

AWS IAM Least Privilege Lab

Assignment 16 — Creating restricted IAM users, auditing over-broad permissions, and writing custom least-privilege JSON policies.

Student	Shreya Panchal
Assignment	16
Topic	AWS IAM Security
Format	Hands-on Lab + Presentation

AWS IAM

S3

DynamoDB

Least Privilege

Table of Contents

Task 1 — Create IAM User foodieAppTester	3
Step 1. Open IAM	3
Step 2. User Details	3
Step 3. Attach Custom Policy	5
Task 2 — Audit Existing IAM User	6
Task 3 — Restrict the Policy	7
Task 4 — Upload Only Profile Pictures	9
Task 5 — 3-Minute Presentation	11

TASK 1

Create IAM User foodieAppTester

● GOAL

User sirf **S3 buckets list** kar sake, create/delete nahi.

Step 1. Open IAM

1. AWS Console → Search **IAM**
2. Left side → Users
3. Click **Create user**

Step 2. User Details

User creation fields

Field	Value
User name	foodieAppTester
Console access	Provide access enabled

Set a password → Next

Specify user details

User details

User name

foodieAppTester

The user name can have up to 64 characters. Valid characters: A-Z, a-z, 0-9, and + = , . _ - (hyphen)

☒ **Provide user access to the AWS Management Console - optional**
In addition to console access, users with `SignInLocalDevelopmentAccess` permissions can use the same console credentials for programmatic access without the need for access keys.

Console password

☒ **Autogenerated password**
You can view the password after you create the user.

☐ **Custom password**
Enter a custom password for the user.

- Must be at least 8 characters long
- Must include at least three of the following mix of character types: uppercase letters (A-Z), lowercase letters (a-z), numbers (0-9), and symbols ! @ # \$ % ^ & * () _ + - (hyphen) = [] { } | ' "

☐ **Show password**

☒ **Users must create a new password at next sign-in - Recommended**
Users automatically get the `IAMUserChangePassword` policy to allow them to change their own password.

Specify user details — user name set to foodieAppTester with console access enabled

The screenshot shows the 'Set permissions' step in the AWS IAM console. The left sidebar indicates the progress: Step 1 (Specify user details), Step 2 (Set permissions), Step 3 (Review and create), and Step 4 (Retrieve password). The main content area is titled 'Set permissions' and includes a sub-header 'Permissions options'. Three options are available: 'Add user to group', 'Copy permissions', and 'Attach policies directly'. The 'Attach policies directly' option is selected. Below this, there is a section for 'Permissions policies (1566)' with a search bar and a table listing policies. The table has columns for 'Policy name', 'Type', and 'Attached entities'. Two policies are visible: 'AccessAnalyzerServiceRolePolicy' and 'AccountAccessManagerServiceRolePolicy', both of type 'AWS managed' and with 0 attached entities.

Set permissions step — Attach policies directly option selected

The screenshot shows the 'Specify permissions' step in the AWS IAM console. The left sidebar indicates the progress: Step 1 (Specify permissions), Step 2 (Review and create). The main content area is titled 'Specify permissions' and includes a sub-header 'Policy editor'. The 'JSON' tab is selected, showing a custom policy document. The document is a JSON object with a 'Version' of '2012-10-17' and a 'Statement' containing a single permission statement. The statement has a 'Sid' of 'ListBucketsOnly', an 'Effect' of 'Allow', and an 'Action' of 's3:ListAllMyBuckets' and 's3:GetBucketLocation'. The 'Resource' is set to '*'. On the right side, there is a panel for 'Add actions' with a search bar and a list of services. The 'Included' section shows 'S3' is selected, and the 'Available' section lists other services like 'AI Operations', 'AMP', 'API Gateway', and 'API Gateway V2'.

Create policy — JSON editor used to paste the custom policy code

The screenshot shows the 'Review and create' step in the AWS IAM console. The left sidebar indicates the progress: Step 1 (Specify permissions), Step 2 (Review and create). The main content area is titled 'Review and create' and includes a sub-header 'Policy details'. The 'Policy name' field is filled with 'FoodieAppBucketListOnly'. The 'Description - optional' field is filled with 'List S3 buckets only'. Below this, there is a section for 'Permissions defined in this policy' with a search bar. The 'Edit' button is visible in the top right corner.

Review and create — policy named FoodieAppBucketListOnly before saving

Step 3. Attach Custom Policy

1. Click **Create policy** → JSON tab → Paste Code
2. Save policy as: `FoodieAppBucketListOnly`
3. Now attach it to `foodieAppTester`.

● RESULT

User bucket dekh sakta hai but create/delete nahi.

TASK 2

Audit Existing IAM User

Assume ek existing user hai `AdminUser` .

● NAVIGATE TO

IAM → Users → AdminUser → Permissions

Suppose attached policy is: `AdministratorAccess`

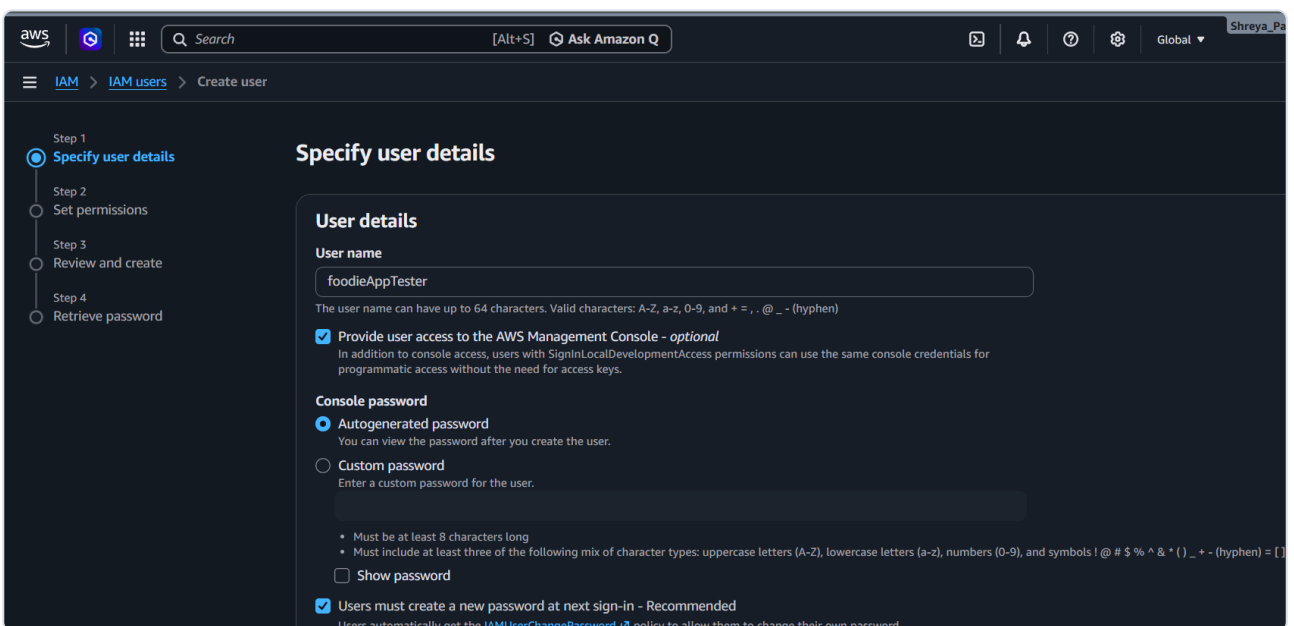
Find 2 Overly Broad Permissions

Overly broad permissions identified

Broad Permission	Problem
<code>s3:*</code>	All S3 actions allowed
<code>dynamodb:*</code>	Full database control

● TIP

Presentation me ye likhna hai.



Screenshot included with this step in the original document

TASK 3

Restrict the Policy

Ab full access remove karke **least privilege** lagao.

Create New Policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "S3ReadWriteMenuBucket",
      "Effect": "Allow",
      "Action": [
        "s3:GetObject",
        "s3:PutObject"
      ],
      "Resource": "arn:aws:s3:::food-menu-storage/*"
    },
    {
      "Sid": "DynamoDBOrders",
      "Effect": "Allow",
      "Action": [
        "dynamodb:GetItem",
        "dynamodb:PutItem",
        "dynamodb:UpdateItem"
      ],
      "Resource": "arn:aws:dynamodb:ap-south-1:123456789012:table/Orders"
    }
  ]
}
```

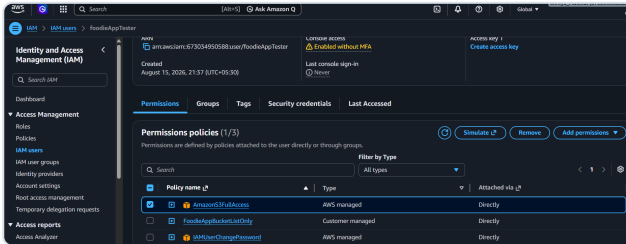
● NOTE

Attach this policy and remove **AdministratorAccess**.

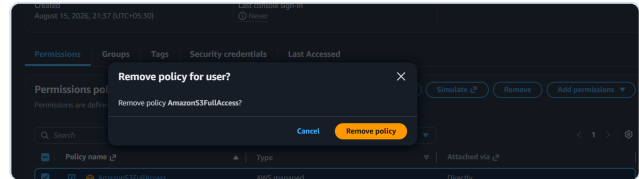
Before vs After

Policy comparison

Before	After
AdministratorAccess	Custom Least Privilege
All S3	Only Menu Bucket
All DynamoDB	Only Orders table



foodieAppTester's Permissions tab — the overly broad AmazonS3FullAccess policy attached



Removing the AmazonS3FullAccess policy to enforce least privilege

TASK 4

Upload Only Profile Pictures

Bucket name: `user-profile-pics`

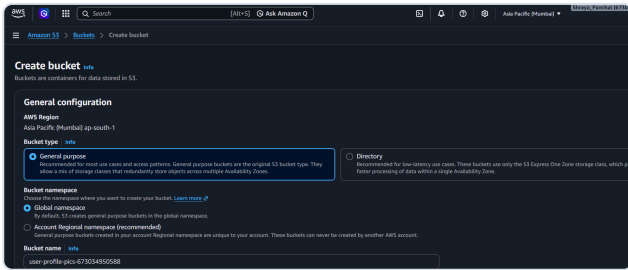
Create This Policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "UploadProfilePictures",
      "Effect": "Allow",
      "Action": [
        "s3:PutObject"
      ],
      "Resource": "arn:aws:s3:::user-profile-pics/*"
    },
    {
      "Sid": "ListBucket",
      "Effect": "Allow",
      "Action": "s3:ListBucket",
      "Resource": "arn:aws:s3:::user-profile-pics"
    }
  ]
}
```

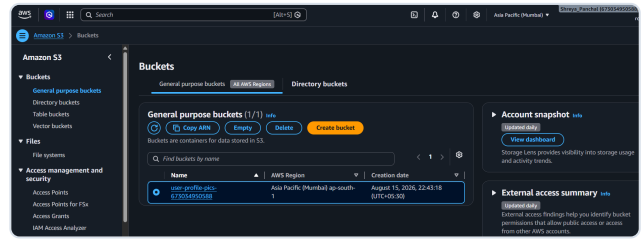
Permission Explanation

What each permission allows

Permission	Meaning
<code>s3:PutObject</code>	Upload image
<code>s3:ListBucket</code>	Bucket open/list
No Delete	Image delete nahi kar sakta
No Create Bucket	Naya bucket nahi bana sakta



Creating the user-profile-pics bucket in the S3 console



The user-profile-pics bucket successfully created

TASK 5

3-Minute Presentation

1 Slide 1 — Objective

Implement **Least Privilege** in AWS IAM

- Created IAM user
- Audited permissions
- Restricted access
- Applied custom JSON policy

2 Slide 2 — Configuration

User	Permission
foodieAppTester	List Buckets Only
App User	Upload Profile Pictures

3 Slide 3 — Before & After

Before	After
AdministratorAccess	Custom Policy
s3:*	PutObject Only
dynamodb:*	Get/Put/Update Only

4 Slide 4 — Security Improvement

Enable **MFA** + Remove AdministratorAccess

● BENEFITS

- Reduces attack surface
- Prevents accidental deletion
- Follows Least Privilege principle